

Guía Metodológica Detallada para la Encuesta de Indicadores SIEM

Versión 1.0 – Apoyo a la recogida, análisis e interpretación de la encuesta sobre métricas SIEM en organizaciones con presencia en España.

1. Objetivo y alcance de la encuesta

La encuesta pretende recolectar información estructurada sobre el grado de implantación, uso y aprovechamiento de plataformas SIEM y capacidades de monitorización de seguridad en organizaciones españolas y multinacionales con actividad relevante en España. Se alinea con las tendencias recogidas en informes de ENISA, la evolución regulatoria (NIS2, ENS, DORA) y las prácticas actuales de SOC en 2025–2026.

La finalidad última es triple:

1. Medir la madurez operativa de los SIEM (velocidad, calidad, cobertura).
2. Evaluar el grado de alineamiento con requisitos normativos y de reporting.
3. Explorar hasta qué punto el SIEM se utiliza como motor de gestión de riesgo y no solo como repositorio de logs.

La encuesta no pretende ser un examen, sino un espejo razonablemente fiel. La honestidad del encuestado pesa más que la perfección formal.

2. Población objetivo y estrategia de muestreo

2.1 Población objetivo

La población objetivo incluye:

- Operadores de servicios esenciales e importantes según NIS2.
- Organizaciones sujetas al Esquema Nacional de Seguridad.
- Entidades financieras y aseguradoras relevantes por su impacto sistémico.
- Operadores de infraestructuras críticas (energía, transporte, comunicaciones, sanidad, agua).
- Grandes corporaciones con SOC/SIEM propios o externalizados.
- Entidades del sector público estatal, autonómico y local con capacidades de monitorización.

El foco geográfico es España, pero se aceptan respuestas de grupos multinacionales siempre que puedan caracterizar el ámbito español.

2.2 Muestreo

Idealmente se utilizará un muestreo estratificado por:

- Sector (energía, finanzas, administración, transporte, sanidad, etc.).
- Tamaño (número de empleados).
- Tipo de entidad (pública, privada, operador esencial/importante, etc.).

Se recomienda asegurar:

- Representación mínima en cada sector crítico.
- Inclusión equilibrada de distintos modelos de SOC (interno, híbrido, externalizado).

En la práctica, se podrá combinar:

- Invitaciones dirigidas (a través de asociaciones, CERT, reguladores).
- Difusión abierta controlada (webs institucionales, foros profesionales).

3. Estructura de la encuesta y lógica de secciones

La encuesta se organiza en nueve secciones que siguen un hilo lógico:

4. Perfil: caracterización básica de la organización y del encuestado.
5. Arquitectura SIEM: tipo de solución, cobertura de fuentes, calidad de datos.
6. Indicadores operativos: velocidad, calidad, cobertura.
7. Cumplimiento normativo: uso del SIEM para NIS2, ENS, DORA, etc.
8. IA y automatización: nivel de modernización del SOC.
9. OT e infraestructuras específicas: atención a entornos industriales y 5G.
10. Riesgo e impacto: uso del SIEM en claves actuariales y de negocio.
11. Ecosistema nacional: colaboración con CERT, alineamiento con marcos europeos.
12. Preguntas abiertas: espacio para matices, ideas y catarsis.

Esta estructura permite:

- Análisis segmentado por temática.
- Mapeo sencillo a requisitos normativos.
- Construcción de indicadores globales de madurez (IGM) y de uso estratégico del SIEM.

4. Escalas de respuesta y criterios de interpretación

4.1 Escalas de madurez (0-5)

La encuesta utiliza una escala de 0 a 5 en varias preguntas para medir madurez. Una interpretación sugerida es:

- 0: inexistente; ningún proceso, métrica o capacidad identificable.
- 1: muy incipiente; iniciativas aisladas, sin estandarización ni seguimiento.
- 2: parcial; proceso definido en algunos ámbitos, sin cobertura global.
- 3: definido; proceso implantado de forma mayoritaria, con seguimiento básico.
- 4: integrado; proceso consolidado, con indicadores y mejora continua.
- 5: optimizado; proceso automatizado, con revisión periódica y alineado con negocio.

Estas puntuaciones se pueden promediar por sección (por ejemplo, “madurez de calidad de datos”) o globalmente para crear un índice de madurez SIEM/SOC.

4.2 Escalas porcentuales y rangos

Las preguntas de rango porcentual (por ejemplo, cobertura de activos, técnicas MITRE ATT&CK, conversión alerta-incidente) están diseñadas para evitar una falsa precisión. Se recomiendan interpretaciones:

- 0–20 %: cobertura muy baja; situación de riesgo evidente.
- 21–40 %: cobertura insuficiente; prioridad alta de mejora.
- 41–60 %: cobertura moderada; se requiere plan de expansión.
- 61–80 %: cobertura buena; prioridad en calidad y uso.
- 81–95 %: cobertura muy buena; enfoque en optimización.
-

95 %: cobertura casi total; sospechar de optimismo excesivo y verificar.

95 %: cobertura casi total; sospechar de optimismo excesivo y verificar.

5. Mapeo conceptual a marcos y buenas prácticas

Aunque la encuesta no recita normas, sus secciones beben de:

- Guías de ENISA sobre creación y operación de SOC y CSIRT.
- Requisitos de NIS2 en materia de gestión de riesgos y notificación de incidentes.
- ENS como marco de referencia para el sector público español.
- Tendencias de SIEM moderno (cloud-native, integración con SOAR, IA).
- Índices de capacidad nacional como el NCSI y marcos de madurez de ciberseguridad.

La Guía de Mapeo detallado (documento independiente) desglosa, pregunta a pregunta, la conexión con artículos, controles o recomendaciones concretas.

6. Procedimiento de recogida de datos

6.1 Formato de la encuesta

Se recomienda implementar la encuesta en:

- Plataforma online segura (por ejemplo, herramienta de cuestionarios con autenticación).
- Versión PDF/Markdown para cumplimentación offline, con posterior volcado manual o automatizado.

Requisitos mínimos:

- Conexión cifrada (HTTPS).
- Posibilidad de guardar borradores.
- Identificador anónimo o pseudónimo para análisis (si aplica).
- Registro de fecha y versión del cuestionario.

6.2 Consentimiento y confidencialidad

Antes de iniciar la encuesta:

- Informar claramente del propósito del estudio.
- Especificar si los resultados se presentarán agregados y anonimizados.
- Definir si la organización será identificable (por ejemplo, solo por sector y tamaño).
- Solicitar consentimiento explícito para el tratamiento de datos.

Buenas prácticas:

- Evitar recolectar datos personales innecesarios.
- No solicitar información técnica excesivamente detallada sobre vulnerabilidades concretas.
- Priorizar siempre la seguridad de la información frente al ansia académica.

7. Cálculo del Índice Global de Madurez (IGM)

7.1 Variables básicas

A partir de las respuestas, se pueden construir subíndices:

- IGM_Arquitectura: calidad de datos, cobertura de fuentes, integración de identidad.
- IGM_Operación: MTTR/MTTD, falsos positivos, cobertura MITRE ATT&CK, latencias.
- IGM_Cumplimiento: uso del SIEM para NIS2/ENS, métricas de notificación, mapeo controles.
- IGM_IA_SOAR: uso de analítica avanzada, automatización y KPIs asociados.
- IGM_OT: monitorización y métricas específicas en entornos industriales.
- IGM_Riesgo: integración con gestión de riesgos y ROI de seguridad.

Cada subíndice puede ser la media (o media ponderada) de las preguntas de la sección correspondiente. El IGM global puede definirse como:

$$\begin{aligned} &[\\ \text{IGM}_{\text{global}} &= \frac{\sum_i w_i \cdot \text{IGM}_i}{\sum_i w_i} \\ &] \end{aligned}$$

donde (w_i) son pesos ajustables según el contexto (por ejemplo, mayor peso a operación y riesgo en operadores esenciales).

7.2 Normalización y comparabilidad

Para comparar entre organizaciones:

- Normalizar los subíndices a una escala común (0–100).
- Documentar la fórmula utilizada y mantenerla estable a lo largo del tiempo.
- Explicitar si se asignan pesos diferentes según sector o criticidad.

Se recomienda una aproximación conservadora: empezar con pesos iguales y, más adelante, refinar según evidencia y consenso experto.

8. Enfoque para el cálculo de ROI

El ROI de proyectos SIEM/SOC puede aproximarse a partir de:

- Reducción de incidentes graves (frecuencia, impacto).
- Reducción de tiempos de detección y respuesta.
- Ahorros derivados de automatización (horas de analista liberadas).
- Evitación de multas, sanciones o costes reputacionales ligados a incumplimiento.

En la plantilla de Excel se propone una estructura para:

13. Estimar pérdidas evitadas (basadas en incidentes históricos o escenarios).
14. Calcular costes directos e indirectos del SIEM/SOC.
15. Obtener ratios como ROI anual, período de recuperación, coste por incidente evitado.

La encuesta proporciona algunos de los inputs (madurez, niveles de automatización, uso para decisiones de inversión), que pueden combinarse con datos internos de la organización.

9. Análisis y explotación de resultados

9.1 Análisis descriptivo

Se recomienda:

- Estadísticos básicos (media, mediana, rango) para cada KPI de encuesta.
- Segmentación por sector, tamaño, tipo de SOC y sujeción a NIS2.
- Identificación de “puntos ciegos” (por ejemplo, alta inversión en SIEM pero ausencia de métricas de calidad).

9.2 Análisis comparativo

Posibles líneas:

- Comparar operadores esenciales vs. importantes.
- Contrastar sector público vs. privado.
- Analizar correlaciones: por ejemplo, relación entre madurez de IA/SOAR y MTTD/MTTR.

9.3 Devolución de resultados

Opciones:

- Informe nacional agregado sin identificar organizaciones.
- Informes sectoriales (energía, finanzas, sanidad, etc.).
- Informes personalizados de benchmarking (cada organización vs. media de su sector).

En todos los casos, la narrativa debe ser orientada a la mejora, no al “naming and shaming”.

10. Limitaciones y cautelas

- Sesgo de deseabilidad social: los encuestados tienden a maquillar la realidad. Nada nuevo bajo el sol.
- Heterogeneidad técnica: un mismo término (“SIEM”, “SOC”) puede significar cosas distintas según la casa.
- Evolución tecnológica y regulatoria: el marco puede cambiar, pero la lógica de fondo (medir velocidad, calidad, cobertura y riesgo) es bastante estable.

La encuesta debe revisarse periódicamente (idealmente cada 2–3 años) para integrar nuevas exigencias regulatorias, avances tecnológicos y lecciones aprendidas.

11. Sugerencias para adaptación local

Para ámbitos concretos (por ejemplo, una comunidad autónoma, un sector específico):

- Ajustar el lenguaje (por ejemplo, referencias a normativa autonómica).
- Añadir secciones específicas (por ejemplo, historia clínica electrónica en sanidad).
- Reducir o ampliar el nivel de detalle según madurez estimada del público objetivo.

La clave es mantener el equilibrio entre rigor y usabilidad: demasiadas preguntas y nadie contestará; demasiado pocas, y no se obtendrá inteligencia útil.

Fin de la guía metodológica.